

CHAPTER 7

Security, Compliance, Auditing, and Protection

The sheer size of a Big Data repository brings with it a major security challenge, generating the age-old question presented to IT: How can the data be protected? However, that is a trick question—the answer has many caveats, which dictate how security must be imagined as well as deployed. Proper security entails more than just keeping the bad guys out; it also means backing up data and protecting data from corruption.

The first caveat is access. Data can be easily protected, but only if you eliminate access to the data. That's not a pragmatic solution, to say the least. The key is to control access, but even then, knowing the *who*, *what*, *when*, and *where* of data access is only a start.

The second caveat is availability: controlling where the data are stored and how the data are distributed. The more control you have, the better you are positioned to protect the data.

The third caveat is performance. Higher levels of encryption, complex security methodologies, and additional security layers can all

improve security. However, these security techniques all carry a processing burden that can severely affect performance.

The fourth caveat is liability. Accessible data carry with them liability, such as the sensitivity of the data, the legal requirements connected to the data, privacy issues, and intellectual property concerns.

Adequate security in the Big Data realm becomes a strategic balancing act among these caveats along with any additional issues the caveats create. Nonetheless, effective security is an obtainable, if not perfect, goal. With planning, logic, and observation, security becomes manageable and omnipresent, effectively protecting data while still offering access to authorized users and systems.

PRAGMATIC STEPS TO SECURING BIG DATA

Securing the massive amounts of data that are inundating organizations can be addressed in several ways. A starting point is to basically get rid of data that are no longer needed. If you do not need certain information, it should be destroyed, because it represents a risk to the organization. That risk grows every day for as long as the information is kept. Of course, there are situations in which information cannot legally be destroyed; in that case, the information should be securely archived by an offline method.

The real challenge may be determining whether the data are needed—a difficult task in the world of Big Data, where value can be found in unexpected places. For example, getting rid of activity logs may be a smart move from a security standpoint. After all, those seeking to compromise networks may start by analyzing activity so they can come up with a way to monitor and intercept traffic to break into a network. In a sense, those logs present a serious risk to an organization, and to prevent the logs from being exposed, the best method may be to delete them after their usefulness ends.

However, those logs could be used to determine scale, use, and efficiency of large data systems, an analytical process that falls right under the umbrella of Big Data analytics. Here a catch-22 is created: Logs are a risk, but analyzing those logs properly can mitigate risks as well. Should you keep or dispose of the data in these cases?

There is no easy answer to that dilemma, and it becomes a case of choosing the lesser of two evils. If the data have intrinsic value for analytics, they must be kept, but that does not mean they need to be kept on a system that is connected to the Internet or other systems. The data can be archived, retrieved for processing, and then returned to the archive.

CLASSIFYING DATA

Protecting data becomes much easier if the data are classified—that is, the data should be divided into appropriate groupings for management purposes. A classification system does not have to be very sophisticated or complicated to enable the security process, and it can be limited to a few different groups or categories to keep things simple for processing and monitoring.

With data classification in mind, it is essential to realize that all data are not created equal. For example, Internal e-mails between two colleagues should not be secured or treated the same way as financial reports, human resources (HR) information, or customer data.

Understanding the classifications and the value of the data sets is not a one-task job; the life-cycle management of data may need to be shared by several departments or teams in an enterprise. For example, you may want to divide the responsibilities among technical, security, and business organizations. Although it may sound complex, it really isn't all that hard to educate the various corporate shareholders to understand the value of data and where their responsibilities lie.

Classification can become a powerful tool for determining the sensitivity of data. A simple approach may just include classifications such as financial, HR, sales, inventory, and communications, each of which is self-explanatory and offers insight into the sensitivity of the data.

Once organizations better understand their data, they can take important steps to segregate the information, which will make the deployment of security measures like encryption and monitoring more manageable. The more data are placed into silos at higher levels, the easier it becomes to protect and control them. Smaller sample sizes are easier to protect and can be monitored separately for specific necessary controls.

PROTECTING BIG DATA ANALYTICS

It is sad to report that protecting data is an often forgotten inclination in the data center, an afterthought that falls behind current needs. The launch of Big Data initiatives is no exception in the data center, and protection is too often an afterthought. Big Data offers more of a challenge than most other data center technologies, making it the perfect storm for a data protection disaster.

The real cause of concern is the fact that Big Data contains all of the things you don't want to see when you are trying to protect data. Big Data can contain very unique sample sets—for example, data from devices that monitor physical elements (e.g., traffic, movement, soil pH, rain, wind) on a frequent schedule, surveillance cameras, or any other type of data that are accumulated frequently and in real time. All of the data are unique to the moment, and if they are lost, they are impossible to recreate.

That uniqueness also means you cannot leverage time-saving backup preparation and security technologies, such as deduplication; this greatly increases the capacity requirements for backup subsystems, slows down security scanning, makes it harder to detect data corruption, and complicates archiving.

There is also the issue of the large size and number of files often found in Big Data analytic environments. In order for a backup application and associated appliances or hardware to churn through a large number of files, bandwidth to the backup systems and/or the backup appliance must be large, and the receiving devices must be able to ingest data at the rate that the data can be delivered, which means that significant CPU processing power is necessary to churn through billions of files.

There is more to backup than just processing files. Big Data normally includes a database component, which cannot be overlooked. Analytic information is often processed into an Oracle, NoSQL, or Hadoop environment of some type, so real-time (or live) protection of that environment may be required. A database component shifts the backup ideology from a massive number of small files to be backed up to a small number of massive files to be backed up. That changes the dynamics of how backups need to be processed.

Big Data often presents the worst-case scenario for most backup appliances, in which the workload mix consists of billions of small files and a small number of large files. Finding a backup solution that can ingest this mixed workload of data at full speed and that can scale to massive capacities may be the biggest challenge in the Big Data backup market.

BIG DATA AND COMPLIANCE

Compliance issues are becoming a big concern in the data center, and these issues have a major effect on how Big Data is protected, stored, accessed, and archived. Whether Big Data is going to reside in the data warehouse or in some other more scalable data store remains unresolved for most of the industry; it is an evolving paradigm. However, one thing is certain: Big Data is not easily handled by the relational databases that the typical database administrator is used to working with in the traditional enterprise database server environment. This means it is harder to understand how compliance affects the data.

Big Data is transforming the storage and access paradigms to an emerging new world of horizontally scaling, unstructured databases, which are better at solving some old business problems through analytics. More important, this new world of file types and data is prompting analysis professionals to think of new problems to solve, some of which have never been attempted before. With that in mind, it becomes easy to see that a rebalancing of the database landscape is about to commence, and data architects will finally embrace the fact that relational databases are no longer the only tool in the tool kit.

This has everything to do with compliance. New data types and methodologies are still expected to meet the legislative requirements placed on businesses by compliance laws. There will be no excuses accepted and no passes given if a new data methodology breaks the law.

Preventing compliance from becoming the next Big Data nightmare is going to be the job of security professionals. They will have to ask themselves some important questions and take into account the growing mass of data, which are becoming increasingly unstructured and are accessed from a distributed cloud of users and applications looking to slice and dice them in a million and one ways. How will

security professionals be sure they are keeping tabs on the regulated information in all that mix?

Many organizations still have to grasp the importance of such areas as payment card industry and personal health information compliance and are failing to take the necessary steps because the Big Data elements are moving through the enterprise with other basic data. The trend seems to be that as businesses jump into Big Data, they forget to worry about very specific pieces of information that may be mixed into their large data stores, exposing them to compliance issues.

Health care probably provides the best example for those charged with compliance as they examine how Big Data creation, storage, and flow work in their organizations. The move to electronic health record systems, driven by the Health Insurance Portability and Accountability Act (HIPAA) and other legislation, is causing a dramatic increase in the accumulation, access, and inter-enterprise exchange of personal identifying information. That has already created a Big Data problem for the largest health care providers and payers, and it must be solved to maintain compliance.

The concepts of Big Data are as applicable to health care as they are to other businesses. The types of data are as varied and vast as the devices collecting the data, and while the concept of collecting and analyzing the unstructured data is not new, recently developed technologies make it quicker and easier than ever to store, analyze, and manipulate these massive data sets.

Health care deals with these massive data sets using Big Data stores, which can span tens of thousands of computers to enable enterprises, researchers, and governments to develop innovative products, make important discoveries, and generate new revenue streams. The rapid evolution of Big Data has forced vendors and architects to focus primarily on the storage, performance, and availability elements, while security—which is often thought to diminish performance—has largely been an afterthought.

In the medical industry, the primary problem is that unsecured Big Data stores are filled with content that is collected and analyzed in real time and is often extraordinarily sensitive: intellectual property, personal identifying information, and other confidential information. The disclosure of this type of data, by either attack or human error, can be devastating to a company and its reputation.

However, because this unstructured Big Data doesn't fit into traditional, structured, SQL-based relational databases, NoSQL, a new type of data management approach, has evolved. These nonrelational data stores can store, manage, and manipulate terabytes, petabytes, and even exabytes of data in real time.

No longer scattered in multiple federated databases throughout the enterprise, Big Data consolidates information in a single massive database stored in distributed clusters and can be easily deployed in the cloud to save costs and ease management. Companies may also move Big Data to the cloud for disaster recovery, replication, load balancing, storage, and other purposes.

Unfortunately, most of the data stores in use today—including Hadoop, Cassandra, and MongoDB—do not incorporate sufficient data security tools to provide enterprises with the peace of mind that confidential data will remain safe and secure at all times. The need for security and privacy of enterprise data is not a new concept. However, the development of Big Data changes the situation in many ways. To date, those charged with network security have spent a great deal of time and money on perimeter-based security mechanisms such as firewalls, but perimeter enforcement cannot prevent unauthorized access to data once a criminal or a hacker has entered the network.

Add to this the fact that most Big Data platforms provide little to no data-level security along with the alarming truth that Big Data centralizes most critical, sensitive, and proprietary data in a single logical data store, and it's clear that Big Data requires big security.

The lessons learned by the health care industry show that there is a way to keep Big Data secure and in compliance. A combination of technologies has been assembled to meet four important goals:

1. **Control access by process, not job function.** Server and network administrators, cloud administrators, and other employees often have access to more information than their jobs require because the systems simply lack the appropriate access controls. Just because a user has operating system-level access to a specific server does not mean that he or she needs, or should have, access to the Big Data stored on that server.
2. **Secure the data at rest.** Most consumers today would not conduct an online transaction without seeing the familiar padlock

symbol or at least a certification notice designating that particular transaction as encrypted and secure. So why wouldn't you require the same data to be protected at rest in a Big Data store? All Big Data, especially sensitive information, should remain encrypted, whether it is stored on a disk, on a server, or in the cloud and regardless of whether the cloud is inside or outside the walls of your organization.

3. **Protect the cryptographic keys and store them separately from the data.** Cryptographic keys are the gateway to the encrypted data. If the keys are left unprotected, the data are easily compromised. Organizations—often those that have cobbled together their own encryption and key management solution—will sometimes leave the key exposed within the configuration file or on the very server that stores the encrypted data. This leads to the frightening reality that any user with access to the server, authorized or not, can access the key and the data. In addition, that key may be used for any number of other servers. Storing the cryptographic keys on a separate, hardened server, either on the premises or in the cloud, is the best practice for keeping data safe and an important step in regulatory compliance. The bottom line is to treat key security with as much, if not greater, rigor than the data set itself.
4. **Create trusted applications and stacks to protect data from rogue users.** You may encrypt your data to control access, but what about the user who has access to the configuration files that define the access controls to those data? Encrypting more than just the data and hardening the security of your overall environment—including applications, services, and configurations—gives you peace of mind that your sensitive information is protected from malicious users and rogue employees.

There is still time to create and deploy appropriate security rules and compliance objectives. The health care industry has helped to lay some of the groundwork. However, the slow development of laws and regulations works in favor of those trying to get ahead on Big Data. Currently, many of the laws and regulations have not addressed the

unique challenges of data warehousing. Many of the regulations do not address the rules for protecting data from different customers at different levels.

For example, if a database has credit card data and health care data, do the PCI Security Standards Council and HIPAA apply to the entire data store or only to the parts of the data store that have their types of data? The answer is highly dependent on your interpretation of the requirements and the way you have implemented the technology.

Similarly, social media applications that are collecting tons of unregulated yet potentially sensitive data may not yet be a compliance concern. But they are still a security problem that if not properly addressed now may be regulated in the future. Social networks are accumulating massive amounts of unstructured data—a primary fuel for Big Data, but they are not yet regulated, so this is not a compliance concern but remains as a security concern.

Security professionals concerned about how things like Hadoop and NoSQL deployments are going to affect their compliance efforts should take a deep breath and remember that the general principles of data security still apply. The first principle is knowing where the data reside. With the newer database solutions, there are automated ways of detecting data and triaging systems that appear to have data they shouldn't.

Once you begin to map and understand the data, opportunities should become evident that will lead to automating and monitoring compliance and security through data warehouse technologies. Automation offers the ability to decrease compliance and security costs and still provide the higher levels of assurance, which validates where the data are and where they are going.

Of course, automation does not solve every problem for security, compliance, and backup. There are still some very basic rules that should be used to enable security while not derailing the value of Big Data:

- **Ensure that security does not impede performance or availability.** Big Data is all about handling volume while providing results, being able to deal with the velocity and variety

of data, and allowing organizations to capture, analyze, store, or move data in real time. Security controls that limit any of these processes are a nonstarter for organizations serious about Big Data.

- **Pick the right encryption scheme.** Some data security solutions encrypt at the file level or lower, such as including specific data values, documents, or rows and columns. Those methodologies can be cumbersome, especially for key management. File level or internal file encryption can also render data unusable because many applications cannot analyze encrypted data. Likewise, encryption at the operating system level, but without advanced key management and process-based access controls, can leave Big Data woefully insecure. To maintain the high levels of performance required to analyze Big Data, consider a transparent data encryption solution optimized for Big Data.
- **Ensure that the security solution can evolve with your changing requirements.** Vendor lock-in is becoming a major concern for many enterprises. Organizations do not want to be held captive to a sole source for security, whether it is a single-server vendor, a network vendor, a cloud provider, or a platform. The flexibility to migrate between cloud providers and models based on changing business needs is a requirement, and this is no different with Big Data technologies. When evaluating security, you should consider a solution that is platform-agnostic and can work with any Big Data file system or database, including Hadoop, Cassandra, and MongoDB.

THE INTELLECTUAL PROPERTY CHALLENGE

One of the biggest issues around Big Data is the concept of intellectual property (IP). First we must understand what IP is, in its most basic form. There are many definitions available, but basically, intellectual property refers to creations of the human mind, such as inventions, literary and artistic works, and symbols, names, images, and designs used in commerce. Although this is a rather broad description, it conveys the essence of IP.

With Big Data consolidating all sorts of private, public, corporate, and government data into a large data store, there are bound to be pieces of IP in the mix: simple elements, such as photographs, to more complex elements, such as patent applications or engineering diagrams. That information has to be properly protected, which may prove to be difficult, since Big Data analytics is designed to find nuggets of information and report on them.

Here is a little background: Between 1985 and 2010, the number of patents granted worldwide rose from slightly less than 400,000 to more than 900,000. That's an increase of more than 125 percent over one generation (25 years). Patents are filed and backed with IP rights (IPRs).

Technology is obviously pushing this growth forward, so it only makes sense that Big Data will be used to look at IP and IP rights to determine opportunity. This should create a major concern for companies looking to protect IP and should also be a catalyst to take action. Fortunately, protecting IP in the realm of Big Data follows many of the same rules that organizations have already come to embrace, so IP protection should already be part of the culture in any enterprise.

The same concepts just have to be expanded into the realm of Big Data. Some basic rules are as follows:

- **Understand what IP is and know what you have to protect.** If all employees understand what needs to be protected, they can better understand how to protect it and whom to protect it from. Doing that requires that those charged with IP security in IT (usually a computer security officer, or CSO) must communicate on an ongoing basis with the executives who oversee intellectual capital. This may require meeting at least quarterly with the chief executive, operating, and information officers and representatives from HR, marketing, sales, legal services, production, and research and development (R&D). Corporate leaders will be the foundation for protecting IP.
- **Prioritize protection.** CSOs with extensive experience normally recommend doing a risk and cost-benefit analysis. This may require you to create a map of your company's assets and determine what information, if lost, would hurt your company the most. Then consider which of those assets are most at risk of

being stolen. Putting these two factors together should help you figure out where to best allocate your protective efforts.

- **Label.** Confidential information should be labeled appropriately. If company data are proprietary, note that on every log-in screen. This may sound trivial, but in court you may have to prove that someone who was not authorized to take information had been informed repeatedly. Your argument won't stand up if you can't demonstrate that you made this clear.
- **Lock it up.** Physical as well as digital protection schemes are a must. Rooms that store sensitive data should be locked. This applies to everything from the server farm to the file room. Keep track of who has the keys, always use complex passwords, and limit employee access to important databases.
- **Educate employees.** Awareness training can be effective for plugging and preventing IP leaks, but it must be targeted to the information that a specific group of employees needs to guard. Talk in specific terms about something that engineers or scientists have invested a lot of time in, and they will pay attention. Humans are often the weakest link in the defense chain. This is why an IP protection effort that counts on firewalls and copyrights but ignores employee awareness and training is doomed to fail.
- **Know your tools.** A growing variety of software tools are available for tracking documents and other IP stores. The category of data loss protection (or data leakage prevention) grew quickly in the middle of the first decade of this century and now shows signs of consolidation into other security tool sets. Those tools can locate sensitive documents and keep track of how they are being used and by whom.
- **Use a holistic approach.** You must take a panoramic view of security. If someone is scanning the internal network, your internal intrusion detection system goes off, and someone from IT calls the employee who is doing the scanning and says, "Stop doing that." The employee offers a plausible explanation, and that's the end of it. Later the night watchman sees an employee carrying out protected documents, whose explanation, when

stopped, is “Oops, I didn’t realize that got into my briefcase.” Over time, the HR group, the audit group, the individual’s colleagues, and others all notice isolated incidents, but no one puts them together and realizes that all these breaches were perpetrated by the same person. This is why communication gaps between infosecurity and corporate security groups can be so harmful. IP protection requires connections and communication among all the corporate functions. The legal department has to play a role in IP protection, and so does HR, IT, R&D, engineering, and graphic design. Think holistically, both to protect and to detect.

- **Use a counterintelligence mind-set.** If you were spying on your own company, how would you do it? Thinking through such tactics will lead you to consider protecting phone lists, shredding the papers in the recycling bins, convening an internal council to approve your R&D scientists’ publications, and coming up with other worthwhile ideas for your particular business.

These guidelines can be applied to almost any information security paradigm that is geared toward protecting IP. The same guidelines can be used when designing IP protection for a Big Data platform.

